M20 # CI/CD & Sécurité Production

Méthodologie Advanced

Utiliser Claude Code en production avec les bonnes garanties de sécurité

Le flag `--dangerously-skip-permissions`

Ce flag contourne les demandes de permission. Les tâches non interactives peuvent aussi utiliser des outils pré-approuvés et un ensemble d'outils restreint. Mais il supprime aussi la dernière ligne de défense contre les actions destructives. Son utilisation n'est acceptable que dans un container éphémère isolé, jamais sur une machine partagée persistante.

```
# Acceptable en CI (container éphémère)
claude --dangerously-skip-permissions \
  -p "Run tests and fix failing ones"

# Inacceptable (machine partagée, accès réseau libre)
claude --dangerously-skip-permissions  # ❌
```

La règle : le flag élargit la confiance accordée à Claude, donc le périmètre du container doit compenser en réduisant ce que Claude peut atteindre.

Environnement recommandé

Un container Docker jetable créé au début du job et détruit à la fin. Le dépôt est monté en volume, les dépendances installées à l'intérieur, et aucun fichier sensible de la machine hôte n'est accessible.

```
jobs:
  agent-review:
    runs-on: ubuntu-latest
    permissions:
      contents: read
    steps:
      - uses: actions/checkout@v4
      - uses: anthropics/claude-code-action@v1
        with:
          anthropic_api_key: ${{ secrets.ANTHROPIC_API_KEY }}
          prompt: "Review the checked-out source and summarize defects."
          claude_args: '--tools "Read,Grep,Glob" --allowedTools
"Read,Grep,Glob"'
```

Cet exemple donne accès en lecture au code source. Identifiants, isolation du runner et déclencheurs du workflow nécessitent une revue séparée. Une microVM ajoute une frontière de noyau ; aucune virtualisation n'élimine tous les risques d'évasion ou d'accès aux données.

Whitelist d'outils stricte

Même en mode bypass, il est possible de limiter les outils disponibles. Un agent de review n'a besoin que de `Read`, `Glob`, `Grep`. Un agent d'implémentation peut avoir `Edit` sur des chemins ciblés, mais rarement `Bash` sans contrainte.

Rôle de l'agent	Outils autorisés
Review de code	Read, Glob, Grep
Correction de tests	Read, Edit, Bash(test runner)
Analyse de sécurité	Read, Glob, Grep
Implémentation	Read, Edit, Write, Bash

Utiliser `--tools` pour limiter les outils disponibles et `--allowedTools` pour pré-approuver les appels autorisés. Transmettre ces options via `claude_args` dans l'action officielle.

Secrets en CI

Les clés API et tokens ne doivent jamais apparaître dans le fichier YAML du workflow. Utiliser les secrets GitHub (Settings → Secrets and variables → Actions) et les injecter en variables d'environnement.

```
env:
  ANTHROPIC_API_KEY: ${{ secrets.ANTHROPIC_API_KEY }}
  # Jamais :
  # ANTHROPIC_API_KEY: sk-ant-xxxxx ❌
```

Rotation recommandée : changer les clés tous les 90 jours et auditer les accès via les logs GitHub.

Réseau : accès restreint

Ne jamais exécuter Claude en mode bypass avec un accès réseau non restreint. Configurer une allowlist réseau explicite pour les domaines légitimes :

```
api.anthropic.com   # Modèle
*.npmjs.org         # Packages
github.com          # Git operations
```

Tout le reste est refusé par défaut. Cela restreint les destinations, mais un service autorisé peut recevoir des données sensibles. Examiner identifiants, périmètre des requêtes et données accessibles à l'agent.

Pattern safe autonomy

Le pattern le plus sûr pour la production : Claude propose, un humain approuve. L'agent ouvre une PR avec ses changements, la pipeline de tests valide, et un reviewer humain approuve avant le merge.

```
Agent → branche → PR → CI tests → human review → merge
```

Ne pas automatiser le merge final, même si tous les tests passent. Garder un humain dans la boucle pour les changements vers main.

Anti-patterns à éviter

Anti-pattern	Risque
Skip permissions sur machine hôte	Accès filesystem/réseau non borné
Monter `/home` dans le container	Exposition des clés SSH, credentials
Allowlist réseau `*`	Exfiltration possible
Merge automatique sans review	Régression non détectée